H.E.I.M.D.A.L.L

Hierarchical Entity Inspection, Masking, and Data-Abstraction LLM Layer

"AI Secured: Innovation Without Exposure"

IBM Z Datathon 2026 (SSF2026) · Secure AI

Team Aegis

Hareesh V · Muhammed Shifas NK · Devi Vrinda A · Rithun K P · Shyaam Menon

https://github.com/HV2337/heimdall

The Problem

KEY VULNERABILITIES

Hospitals want AI assistants over patient records. That creates three risks:

01 Users paste personal data into prompts.

02 Assistants ignore who may see what.

03 Attackers use prompt injection.

243M

People affected across 663 breaches (500+ people)

source: HHS 2024 report to Congress

$9.77M

Average cost of a healthcare data breach

source: IBM Cost of a Data Breach 2024

70%+

Of 100 US healthcare leaders pursuing or using generative AI

source: McKinsey, Q1 2024

A gateway between users and the model

01 **Permissions First**

Access is checked before any data is read.

02 **Tokenized Data**

The model sees tokens, not real values. [PERSON_1]; dates and amounts become bands.

03 **Output Verification**

Output is checked before it leaves. Raw-pattern scan, per-request canary, forged-marker check.

04 **Fails Closed**

Any failure stops the request with a generic 403/503.

Healthcare example, synthetic data only. The model is a mock in this build.

Ten steps, fail closed

End-to-end execution pipeline and failure handling

GATEWAY ARCHITECTURE DIAGRAM



01 Early Enforcement

Permissions run at step 2, before any data is read.

02 Fail-Closed Gates

Red borders mark the steps that can reject a request.

Same question, three roles

Same question, different permitted fields

Doctor

- Full record
- All fields permitted by policy
- Dates and amounts shown as bands, e.g. [25000+]

Nurse

- ID
- Meds
- Vitals
- Ward

Billing Clerk

- ID
- Name
- Phone
- Billing amount

CONSOLE LOG — PIPELINE DEMO OUTPUT

```
(heimdall-env) linux1@heimdall:~/heimdall$ python scripts/demo_pipeline.py
doctor / same question: HTTP 200; Summary for the requested record(s): [{"billing_amount":"[25000+]","created_at":"2026-01","diagnosis":"Seasonal allergy","
dob":"18-29","id":"1","meds":"Medication B","name":"Ekaja Thakkar","notes":"Synthetic record for demonstration.","phone":"+91-90000-00000","vitals":"systoli
c 120-139; diastolic 90+; pulse 60-99","ward":"Cardiology"}]
nurse / same question: HTTP 200; Summary for the requested record(s): [{"id":"1","meds":"Medication B","vitals":"systolic 120-139; diastolic 90+; pulse 60-9
9","ward":"Cardiology"}]
billing_clerk / same question: HTTP 200; Summary for the requested record(s): [{"billing_amount":"[25000+]","id":"1","name":"Ekaja Thakkar","phone":"+91-900
00-00000"}]
blocked injection: HTTP 403; Request blocked.
PII prompt: HTTP 200; Summary for the requested record(s): [{"billing_amount":"[25000+]","created_at":"2026-01","diagnosis":"Seasonal allergy","dob":"18-29"
,"id":"1","meds":"Medication B","name":"Ekaja Thakkar","notes":"Synthetic record for demonstration.","phone":"+91-90000-00000","vitals":"systolic 120-139; d
iastolic 90+; pulse 60-99","ward":"Cardiology"}]
sanitized_prompt: Request: My phone number is [PHONE_2]; summarize the patient's record.
Permitted records: [{"billing_amount":"[25000+]","created_at":"2026-01","diagnosis":"Seasonal allergy","dob":"18-29","id":"[PATIENT_ID_1]","meds":"Medicatio
n B","name":"[PERSON_1]","notes":"Synthetic record for demonstration.","phone":"[PHONE_1]","vitals":"systolic 120-139; diastolic 90+; pulse 60-99","ward":"C
ardiology"}]
persona classifier: blocked=False, score=0.441448
persona data authorization: HTTP 403; Request blocked.
```

The model sees tokens only

RAW PROMPT (INPUT)

“My phone number is <real number>; summarize the patient’s record.”

SANITIZED PROMPT (SENT TO MODEL)

“My phone number is **[PHONE_2]**; summarize the patient’s record.”

TOKEN MAPPING:

Record tokens: **[PATIENT_ID_1]** · **[PERSON_1]** · **[PHONE_1]**

Generalized: dob “18–29” · billing “[25000+]” · created_at “2026-01”

A missed injection still gets nothing

UNAUTHORIZED DISCLOSURE PER ROLE

0 / 60

Zero unauthorized disclosures

OUTPUT LEAKS

0 / 60

No output leaks recorded

CROSS-SESSION ATTACKS

30 / 30

100% blocked

DATA EXPOSED AFTER A MISSED INJECTION

0 / 201

Role runs (mock model)

Injection attempt → blocked: HTTP 403 “Request blocked.”
Persona attack → classifier score 0.44, not blocked → data authorization still returned HTTP 403

Synthetic probes from our own generators; mock model.

Measured results

TEST METRIC	HEIMDALL	REGEX BASELINE
PII plain probes (recall)	**150 / 150**	147 / 150
PII plain probes (false positives)	**0 / 150**	49 / 150 (32.7%)
PII obfuscated	**50 / 60 (83.3%)**	17 / 60 (28.3%)

Held-out set (n=30), written by a separate AI assistant, not used for tuning

12 / 15 attacks blocked (80.0%)

0 / 15 false positives

Rules only 3/15 · classifier only 10/15 · combined 12/15

Missed: persona impersonation, fake [SYSTEM] message, instruction hidden in a billing note

Built and tested on LinuxONE

ENVIRONMENT & SCOPE

IBM LinuxONE · s390x (big-endian)
z/VM 7.3 · 3 CPUs · 7.8 GiB RAM

- Classifier trained on this VM; pure-Python inference from portable JSON
- **88** tests pass
- **1,097** requests measured



LATENCY OVERHEAD

STAGE	P50 (MS)	P95 (MS)
Threat	0.30	1.74
Sanitize	0.07	0.20
Output control	0.02	0.15
Normalize	0.02	0.05

Gateway overhead only (mock model). Slowest stage: threat check. No hardware acceleration claimed.

System Limitations & Constraints

What we do not claim

Mock model

The language model is a **mock** in this build. Latency is gateway overhead only.

Small evaluation

Held-out set is **n=30**. Three attacks were missed: persona impersonation, fake [SYSTEM] message, instruction hidden in a billing note.

No k-anonymity guarantee

Measured **k=1** on our small dataset.

Known gaps

Base64 phone numbers under 16 characters are not decoded (**0/10**). Sessions are in memory. The doctor sees billing by policy.

Differences from our abstract

The abstract promised air-gap, secure enclaves and SIEM alerts. None are in this build. Its 5 stages are shown as 10 steps. Details are in the README.

What’s next

01 Transformer classifier on LinuxONE JupyterLab, with a new held-out set.

02 Real LLM backend.

03 Formal k-anonymity.

04 SIEM export.

05 Persistent sessions.

Links and credits

REPOSITORY

GitHub_repo

KEY DOCS

- THIRD_PARTY.md
- docs/THREAT_MODEL.md
- eval/results/final-latest.md

Public datasets used in classifier development and evaluation

Lakera/gandalf_ignore_instructions
License: MIT

jackhhao/jailbreak-classification
License: Apache-2.0

DISCLOSURE

AI Assistance

AI assistants were used for code, evaluation data and documentation.